

# Admin Portal API Reference

This document defines the admin-facing endpoints delivered in Sprint 4: staff oversight, admin self-service and oversight, adopter oversight, shelter management, and org-wide analytics. It follows the same conventions established in 08-Public\_API\_Reference — see that document for base URL, standard response structure, and error code definitions, which are not repeated here. All endpoints below require Admin role auth (Bearer token) unless otherwise noted.

## 1. Staff Management

### 1.1 GET /api/v1/staff

Returns a paginated, org-wide staff list, ordered by staffName ascending.

#### Request

| Field         | Value                                                                                                                                                                                                                                                                     |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method        | GET                                                                                                                                                                                                                                                                       |
| Auth required | Yes — Admin only                                                                                                                                                                                                                                                          |
| Query params  | page (int, optional, default 1), limit (int, optional, default 20), shelterID (int, optional filter), staffDesignation (optional — one of Manager/Senior/Associate), accountStatus (optional — one of Pending/Active/Deactivated — Pending means awaiting admin approval) |

#### Response

```
200 OK
{
  "success": true,
  "message": "Staff retrieved successfully",
  "data": [
    {
      "userID": 5,
      "avatarSeed": "a1b2c3d4-...",
      "staffName": "...",
      "staffPhone": "...",
      "shelterID": 3,
      "staffDOB": "1990-04-12",
      "staffSex": "F",
      "staffDOJ": "2024-01-15",
      "staffDOS": null,
      "staffDesignation": "Manager",
      "accountStatus": "Active",
      "user": { "userEmail": "..." }
    }
  ],
  "pagination": { "page": 1, "limit": 20, "total": 12, "totalPages": 1 }
}
```

#### Error Cases

| Scenario                                        | Error Code  | HTTP Status |
|-------------------------------------------------|-------------|-------------|
| Invalid page or limit                           | BAD_REQUEST | 400         |
| Invalid shelterID                               | BAD_REQUEST | 400         |
| Invalid staffDesignation or accountStatus value | BAD_REQUEST | 400         |

## 1.2 GET /api/v1/staff/:id

Returns full detail for one staff member — the same fields as a list item (1.1), plus managedShelters: the shelter(s) this person currently manages, if any.

### Request

| Field         | Value                       |
|---------------|-----------------------------|
| Method        | GET                         |
| Auth required | Yes — Admin only            |
| Path params   | id (int, required) — userID |

### Response

```
200 OK
{
  "success": true,
  "message": "Staff member retrieved successfully",
  "data": {
    "userID": 5,
    "avatarSeed": "a1b2c3d4-...",
    "staffName": "...",
    "staffPhone": "...",
    "shelterID": 3,
    "staffDOB": "1990-04-12",
    "staffSex": "F",
    "staffDOJ": "2024-01-15",
    "staffDOS": null,
    "staffDesignation": "Manager",
    "accountStatus": "Active",
    "user": { "userEmail": "..." },
    "managedShelters": [ { "shelterID": 3, "shelterName": "..." } ]
  }
}
```

### Error Cases

| Scenario                     | Error Code  | HTTP Status |
|------------------------------|-------------|-------------|
| id is not a positive integer | BAD_REQUEST | 400         |
| Staff member does not exist  | NOT_FOUND   | 404         |

## 1.3 PATCH /api/v1/staff/:id

Partial update to a staff member's profile. staffDesignation and/or shelterID may be updated (account activation is a separate endpoint, 1.4).

### Request

| Field         | Value                                                                                                                        |
|---------------|------------------------------------------------------------------------------------------------------------------------------|
| Method        | PATCH                                                                                                                        |
| Auth required | Yes — Admin only                                                                                                             |
| Path params   | id (int, required) — userID                                                                                                  |
| Body fields   | Any subset of: shelterID (int), staffDesignation (one of Manager/Senior/Associate), and other updatable staff profile fields |

*Manager sync, two directions: (a) if shelterID changes and this staff member currently manages their old shelter, that shelter's managerStaffID is cleared automatically — a manager can't be reassigned to a new branch while still listed as managing the old one. (b) staffDesignation and Shelter.managerStaffID are kept in sync: setting designation to 'Manager' makes this person the managerStaffID of their (possibly new) shelter, overwriting any existing manager there; moving away from 'Manager' (or away from that shelter) clears managerStaffID on the shelter they were managing.*

### Response

200 OK, same shape as the detail response in 1.2.

### Error Cases

| Scenario                                        | Error Code  | HTTP Status |
|-------------------------------------------------|-------------|-------------|
| No updatable fields provided                    | BAD_REQUEST | 400         |
| Invalid staffDesignation value                  | BAD_REQUEST | 400         |
| shelterID is not a positive integer             | BAD_REQUEST | 400         |
| shelterID doesn't reference an existing shelter | NOT_FOUND   | 404         |
| Staff member does not exist                     | NOT_FOUND   | 404         |

## 1.4 PATCH /api/v1/staff/:id/status

Activates or deactivates a staff account.

### Request

| Field         | Value                                                                                                                                             |
|---------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| Method        | PATCH                                                                                                                                             |
| Auth required | Yes — Admin only                                                                                                                                  |
| Path params   | id (int, required) — userID                                                                                                                       |
| Body fields   | accountStatus (string, required — "Active" or "Deactivated"; Pending is never an accepted target — there is no manual revert-to-Pending workflow) |

*This is also how a self-registered Pending staff account is approved (→ Active) or declined (→ Deactivated) — no separate approve/decline endpoint exists. Deactivating clears managerStaffID on every shelter this staff member currently manages. A Deactivated (or still-Pending) staff member is rejected on their next login attempt, and an already-issued access token is separately invalidated immediately by live account-status enforcement on every protected request — not just at next login.*

### Response

200 OK, same detail shape as 1.2.

## Error Cases

| Scenario                         | Error Code  | HTTP Status |
|----------------------------------|-------------|-------------|
| accountStatus missing or invalid | BAD_REQUEST | 400         |
| Staff member does not exist      | NOT_FOUND   | 404         |

## 2. Admin Management

### 2.1 GET /api/v1/admins

Returns a paginated list of admins, ordered by adminName ascending, including self-registered accounts awaiting approval.

#### Request

| Field         | Value                                                                                                                     |
|---------------|---------------------------------------------------------------------------------------------------------------------------|
| Method        | GET                                                                                                                       |
| Auth required | Yes — Admin only                                                                                                          |
| Query params  | page (int, optional, default 1), limit (int, optional, default 20), accountStatus (optional — Pending/Active/Deactivated) |

#### Response

```
200 OK
{
  "success": true,
  "message": "Admins retrieved successfully",
  "data": [
    {
      "userID": 2,
      "avatarSeed": "a1b2c3d4-...",
      "adminName": "...",
      "adminPhone": "...",
      "adminAddress": "...",
      "adminDOB": "1988-03-02",
      "adminSex": "M",
      "createdAt": "2026-01-10T09:00:00Z",
      "lastLoginAt": "2026-09-01T08:30:00Z",
      "accountStatus": "Active",
      "statusChangedAt": "2026-01-10T09:05:00Z",
      "statusChangedBy": { "userID": 1, "adminName": "..." }
    }
  ],
  "pagination": { "page": 1, "limit": 20, "total": 4, "totalPages": 1 }
}
```

*statusChangedBy records who last changed this admin's status, and is null if it has never been changed — an audit trail of the most recent change only, not full history.*

## Error Cases

| Scenario                              | Error Code  | HTTP Status |
|---------------------------------------|-------------|-------------|
| Invalid page, limit, or accountStatus | BAD_REQUEST | 400         |

## 2.2 GET /api/v1/admins/me

Returns the logged-in admin's own profile, same shape as one list item in 2.1.

### Request

| Field            | Value                                       |
|------------------|---------------------------------------------|
| Method           | GET                                         |
| Auth required    | Yes — Admin only                            |
| Path/Body fields | None — admin identified via req.user.userID |

### Response

200 OK, same shape as one item in 2.1's response list.

### Error Cases

| Scenario         | Error Code   | HTTP Status |
|------------------|--------------|-------------|
| No/invalid token | UNAUTHORIZED | 401         |

## 2.3 PUT /api/v1/admins/me

Self-service update to the logged-in admin's own profile.

### Request

| Field         | Value                                                                                                                                                                                                                                                                                                    |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method        | PUT                                                                                                                                                                                                                                                                                                      |
| Auth required | Yes — Admin only                                                                                                                                                                                                                                                                                         |
| Body fields   | avatarSeed (≤64 chars), adminName (≤45 chars), adminPhone (normalized to E.164 server-side), adminAddress (≤45 chars), adminDOB (valid date), adminSex (one of M/F/O). adminPhone/adminAddress/adminDOB/adminSex may be explicitly set to null to clear them; adminName/avatarSeed cannot be null/empty. |

*accountStatus is explicitly rejected here — that's admin-approval-only, via the 1.4-style endpoint (2.7). Providing it returns 400 listing the rejected field(s), before any write occurs.*

### Response

200 OK, updated profile, same shape as 2.2.

### Error Cases

| Scenario                                  | Error Code  | HTTP Status |
|-------------------------------------------|-------------|-------------|
| Rejected field (accountStatus) present    | BAD_REQUEST | 400         |
| A provided field is null but not nullable | BAD_REQUEST | 400         |
| String field too long                     | BAD_REQUEST | 400         |
| Invalid adminSex or adminDOB              | BAD_REQUEST | 400         |

|                              |             |     |
|------------------------------|-------------|-----|
| No updatable fields provided | BAD_REQUEST | 400 |
|------------------------------|-------------|-----|

## 2.4 DELETE /api/v1/admins/me

Self-service account closure for the logged-in admin.

### Request

| Field         | Value                                              |
|---------------|----------------------------------------------------|
| Method        | DELETE                                             |
| Auth required | Yes — Admin only                                   |
| Body fields   | mode (string, required — "deactivate" or "delete") |

*deactivate sets accountStatus to Deactivated and clears the refresh token (self-service, no “last active admin” guard — unlike 2.7 below, this is only ever your own account). delete removes the admin's government ID (including its stored Storage file), the Admin row, and the Users row.*

### Response

```
200 OK
{
  "success": true,
  "message": "Account deleted",
  "data": null
}
```

(or "Account deactivated" depending on mode)

### Error Cases

| Scenario                | Error Code       | HTTP Status |
|-------------------------|------------------|-------------|
| mode missing or invalid | VALIDATION_ERROR | 422         |

## 2.5 GET & POST /api/v1/admins/me/government-id

Identical contract to the Adopter Portal's government-ID endpoints (see 09-Adopter\_API, Section 2), scoped to userType "Admin" instead of "Adopter": same multipart upload (idType, idNumber ≤45 chars, file ≤5MB), same one-per-admin uniqueness (a Rejected record can be resubmitted, overwriting the prior one), same idNumber masking (e.g. \*\*\*\*\*4567) on the POST response, same 404/409 error cases. Self-only — never exposed via GET /admins/:id.

## 2.6 GET /api/v1/admins/:id

Returns full detail for one admin, same shape as a list item (2.1).

### Request

| Field         | Value            |
|---------------|------------------|
| Method        | GET              |
| Auth required | Yes — Admin only |

|             |                             |
|-------------|-----------------------------|
| Path params | id (int, required) — userID |
|-------------|-----------------------------|

## Response

200 OK, same shape as one item in 2.1's response list.

## Error Cases

| Scenario                     | Error Code  | HTTP Status |
|------------------------------|-------------|-------------|
| id is not a positive integer | BAD_REQUEST | 400         |
| Admin does not exist         | NOT_FOUND   | 404         |

## 2.7 PATCH /api/v1/admins/:id/status

Activates or deactivates another admin's account.

## Request

| Field         | Value                                                        |
|---------------|--------------------------------------------------------------|
| Method        | PATCH                                                        |
| Auth required | Yes — Admin only                                             |
| Path params   | id (int, required) — userID                                  |
| Body fields   | accountStatus (string, required — "Active" or "Deactivated") |

*This is also how a self-registered Pending admin is approved or declined; it records the acting admin's userID and the current timestamp as statusChangedAt (shown as statusChangedBy in the response) — an audit trail of the last change only, not full history. An admin cannot deactivate their own account this way (guards against the last active admin locking themselves out with no one left to reverse it) — use 2.4 instead for self-service.*

## Response

200 OK, updated detail, same shape as 2.6.

## Error Cases

| Scenario                         | Error Code  | HTTP Status |
|----------------------------------|-------------|-------------|
| accountStatus missing or invalid | BAD_REQUEST | 400         |
| Self-deactivation attempt        | BAD_REQUEST | 400         |
| Admin does not exist             | NOT_FOUND   | 404         |

# 3. Adopter Oversight

## 3.1 GET /api/v1/adopters

Returns a paginated, org-wide adopter list for admin oversight, ordered by adopterName ascending. Never includes governmentID or stripeCustomerID.

## Request

| Field  | Value |
|--------|-------|
| Method | GET   |

|               |                                                                                                                                                                                                                         |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Auth required | Yes — Admin only                                                                                                                                                                                                        |
| Query params  | page (int, optional, default 1), limit (int, optional, default 20), accountStatus (optional — Active/Banned/Deactivated), adopterRiskFlag (optional boolean — only the exact string "true" filters to flagged adopters) |

## Response

```
200 OK
{
  "success": true,
  "message": "Adopters retrieved successfully",
  "data": [
    {
      "userID": 12,
      "avatarSeed": "a1b2c3d4-...",
      "adopterName": "...",
      "adopterPhone": "...",
      "accountStatus": "Active",
      "adopterRiskFlag": false,
      "preQualifyFlag": true,
      "createdAt": "2026-02-01T10:00:00Z",
      "city": "...",
      "state": "...",
      "country": "..."
    }
  ],
  "pagination": { "page": 1, "limit": 20, "total": 340, "totalPages": 17 }
}
```

## Error Cases

| Scenario                              | Error Code  | HTTP Status |
|---------------------------------------|-------------|-------------|
| Invalid page, limit, or accountStatus | BAD_REQUEST | 400         |

## 3.2 PATCH /api/v1/adopters/:id/status

Bans, deactivates, or reactivates an adopter.

### Request

| Field         | Value                                                                   |
|---------------|-------------------------------------------------------------------------|
| Method        | PATCH                                                                   |
| Auth required | Yes — Admin only                                                        |
| Path params   | id (int, required) — userID                                             |
| Body fields   | accountStatus (string, required — "Active", "Banned", or "Deactivated") |

*Banned and Deactivated adopters are rejected on their next login, and transitioning to either of those statuses nulls the adopter's stored refresh token immediately (the same helper the adopter's own self-deactivate flow uses) — this closes the window where an already-issued refresh token could otherwise keep minting fresh access tokens for up to its remaining 7-day life.*

## Response

200 OK, updated adopter summary, same shape as one item in 3.1's response list.

## Error Cases

| Scenario                         | Error Code  | HTTP Status |
|----------------------------------|-------------|-------------|
| accountStatus missing or invalid | BAD_REQUEST | 400         |
| Adopter does not exist           | NOT_FOUND   | 404         |

# 4. Shelter Management

## 4.1 POST /api/v1/shelters

Creates a new shelter. This is the only supported way to add a shelter to the network — no other creation path exists.

### Request

| Field         | Value                                                                                                                                                                                                                                   |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Method        | POST                                                                                                                                                                                                                                    |
| Auth required | Yes — Admin only                                                                                                                                                                                                                        |
| Body fields   | shelterName (≤45 chars, required), shelterAddress (≤45 chars, required), shelterPhone (required, normalized to E.164), shelterEmail (valid email, ≤45 chars, required), shelterZIP (required), shelterSize (positive integer, required) |

*shelterStatus is never accepted here — it always starts as the schema default ("Open"). shelterZIP is geocoded server-side (offline US zip → coords) into a PostGIS point, the same column the public /shelters/nearby search reads; an unresolvable ZIP fails the whole request before any row is written.*

### Response

```
201 Created
{
  "success": true,
  "message": "Shelter created successfully",
  "data": {
    "shelterID": 6,
    "shelterName": "...",
    "shelterAddress": "...",
    "shelterPhone": "...",
    "shelterEmail": "...",
    "shelterZIP": "...",
    "shelterSize": 40,
    "shelterStatus": "Open",
    "managerStaffID": null,
    "lat": 40.7128,
    "lng": -74.006
  }
}
```

## Error Cases

| Scenario                                                                            | Error Code  | HTTP Status |
|-------------------------------------------------------------------------------------|-------------|-------------|
| A required field is missing                                                         | BAD_REQUEST | 400         |
| Field fails validation (bad email format, non-positive ZIP/size, unparseable phone) | BAD_REQUEST | 400         |
| shelterZIP can't be geocoded                                                        | BAD_REQUEST | 400         |

## 4.2 PUT /api/v1/shelters/:id

Partial update to a shelter; only fields present in the body are changed, using the same field set and validation as 4.1.

### Request

| Field         | Value                                  |
|---------------|----------------------------------------|
| Method        | PUT                                    |
| Auth required | Yes — Admin only                       |
| Path params   | id (int, required) — shelterID         |
| Body fields   | Any subset of the fields listed in 4.1 |

*shelterLocation is re-geocoded when shelterAddress or shelterZIP is present in the body (using the new ZIP if provided, otherwise the shelter's existing one) — both the geocode and the DB write share one transaction, so a bad geocode fails cleanly with nothing partially applied.*

### Response

200 OK, same shape as 4.1's response.

### Error Cases

| Scenario                          | Error Code  | HTTP Status |
|-----------------------------------|-------------|-------------|
| No updatable fields provided      | BAD_REQUEST | 400         |
| A provided field fails validation | BAD_REQUEST | 400         |
| ZIP can't be geocoded             | BAD_REQUEST | 400         |
| Shelter does not exist            | NOT_FOUND   | 404         |

## 4.3 PATCH /api/v1/shelters/:id/status

Changes a shelter's shelterStatus.

### Request

| Field         | Value                                                          |
|---------------|----------------------------------------------------------------|
| Method        | PATCH                                                          |
| Auth required | Yes — Admin only                                               |
| Path params   | id (int, required) — shelterID                                 |
| Body fields   | shelterStatus (string, required — "Open", "Full", or "Closed") |

### Response

200 OK, same shape as 4.1's response.

### Error Cases

| Scenario                         | Error Code  | HTTP Status |
|----------------------------------|-------------|-------------|
| shelterStatus missing or invalid | BAD_REQUEST | 400         |
| Shelter does not exist           | NOT_FOUND   | 404         |

## 4.4 PATCH /api/v1/shelters/:id/manager

(Re)assigns the staff member who manages a shelter.

### Request

| Field         | Value                          |
|---------------|--------------------------------|
| Method        | PATCH                          |
| Auth required | Yes — Admin only               |
| Path params   | id (int, required) — shelterID |
| Body fields   | managerStaffID (int, required) |

*managerStaffID must belong to a staff member already assigned to THIS shelter — a staff member who exists but works elsewhere is treated as not-found (404), identical to a nonexistent ID. A Deactivated staff member at the right shelter is rejected with 409 rather than being silently accepted.*

### Response

200 OK, same shape as 4.1's response.

### Error Cases

| Scenario                                                                                  | Error Code  | HTTP Status |
|-------------------------------------------------------------------------------------------|-------------|-------------|
| managerStaffID missing or not a positive integer                                          | BAD_REQUEST | 400         |
| Shelter doesn't exist, or managerStaffID doesn't belong to a staff member at this shelter | NOT_FOUND   | 404         |
| Staff member is Deactivated                                                               | CONFLICT    | 409         |

## 5. Analytics

### 5.1 GET /api/v1/analytics/overview

Returns an org-wide KPI summary. No params. Computed as four grouped-count queries (shelters by shelterStatus, pets by adoptionStatus, adopters by accountStatus, applications by applicationStatus) — O(1) queries regardless of data volume, no per-row loops.

### Request

| Field            | Value            |
|------------------|------------------|
| Method           | GET              |
| Auth required    | Yes — Admin only |
| Path/Body fields | None             |

### Response

200 OK

```
{
  "success": true,
  "message": "Overview retrieved successfully",
  "data": {
    "shelters": { "total": 6, "byStatus": { "Open": 5, "Full": 1, "Closed":
0 } },
    "pets": { "total": 210, "byStatus": { "available": 140, "...": "..." } },
    "adopters": { "total": 340, "byStatus": { "Active": 330, "Banned": 2,
"Deactivated": 8 } },
    "applications": {
      "total": 95,
      "byStatus": { "Pending": 20, "Accepted": 60, "Rejected": 10, "Withdrawn": 5
    },
    "adoptionRate": 0.42
  }
}
```

*adoptionRate is Accepted ÷ total applications, rounded to 2 decimal places — null (not 0) when there are no applications yet, since 0% would misleadingly imply every application was rejected rather than none existing.*

## Error Cases

| Scenario         | Error Code   | HTTP Status |
|------------------|--------------|-------------|
| No/invalid token | UNAUTHORIZED | 401         |

## 5.2 GET /api/v1/analytics/shelters

Returns per-shelter stats, not paginated (this list is also what backs the Admin Shelters tab's list and edit-form pre-fill, not just an analytics view). Ordered by shelterName ascending by default.

### Request

| Field         | Value                                                                                                                                            |
|---------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Method        | GET                                                                                                                                              |
| Auth required | Yes — Admin only                                                                                                                                 |
| Query params  | sortBy (optional — "utilization" or "petCount" — ranks highest-first instead of alphabetical; shelters with no computable utilization sort last) |

### Response

```
200 OK
{
  "success": true,
  "message": "Shelter analytics retrieved successfully",
  "data": [
    {
      "shelterID": 3,
      "shelterName": "...",
      "shelterAddress": "...",
      "shelterPhone": "...",
      "shelterEmail": "...",

```

```
    "shelterZIP": "...",
    "shelterSize": 40,
    "shelterStatus": "Open",
    "managerStaffID": 5,
    "petCount": 28,
    "petsByStatus": { "available": 20, "pending": 5, "adopted": 3 },
    "openApplicationCount": 6,
    "staffCount": 4,
    "utilization": 70.0
  }
]
```

*openApplicationCount counts Pending applications only. staffCount counts Active staff only. utilization is pet count ÷ shelterSize as a PERCENTAGE, 2dp — null, not 0, for a zero-capacity shelter. Note this is a percentage, unlike adoptionRate's 0–1 fraction above.*

## Error Cases

| Scenario                                 | Error Code  | HTTP Status |
|------------------------------------------|-------------|-------------|
| sortBy not one of the two allowed values | BAD_REQUEST | 400         |

## 5.3 GET /api/v1/analytics/monthly-stats

Returns Jan–Dec monthly stats for one calendar year, for the Admin Overview chart.

### Request

| Field         | Value                                                   |
|---------------|---------------------------------------------------------|
| Method        | GET                                                     |
| Auth required | Yes — Admin only                                        |
| Query params  | year (optional int, min 2000, default the current year) |

### Response

```
200 OK
{
  "success": true,
  "message": "Monthly stats retrieved successfully",
  "data": [
    { "month": "Jan", "year": 2026, "intake": 12, "adoptions": 8 },
    { "month": "Feb", "year": 2026, "intake": 9, "adoptions": 6 }
  ]
}
```

*Array of 12 objects in Jan→Dec order. Intake counts pets by Pet.intakeDate; Adoptions counts applications with applicationStatus 'Accepted' by their submission month (createdAt) — the schema has no separate “accepted on” timestamp, the same approximation adoptionRate already makes. All bucketing uses UTC month/year, so results don't shift based on where the server process happens to run.*

## Error Cases

| Scenario | Error Code | HTTP Status |
|----------|------------|-------------|
|----------|------------|-------------|

|                                                          |             |     |
|----------------------------------------------------------|-------------|-----|
| year is not an integer between 2000 and the current year | BAD_REQUEST | 400 |
|----------------------------------------------------------|-------------|-----|